

File Path Traversal

Validation of Start of Path — Nivel Apprentice

Alumno	Manuel Eduardo Hernández Gaytán
Matrícula	181850
Materia	CNO IV – Seguridad Informática
Laboratorio	Actividad 11 · File Path Traversal – Validation of Start of Path
Nivel	Apprentice
Plataforma	PortSwigger Web Security Academy
Docente	Mtro. Servando López Contreras
Fecha	26 de septiembre de 2026

Índice

1. Marco Teórico y Fundamentación Técnica
2. Identificación del Laboratorio
3. Objetivo del Laboratorio
4. Explicación Técnica de la Vulnerabilidad
5. Procedimiento Paso a Paso
6. Capturas de Pantalla Obligatorias
7. Explicación Técnica del Payload
8. Mitigación Recomendada
9. Conclusión

1. Marco Teórico y Fundamentación Técnica

El Path Traversal es una vulnerabilidad de seguridad web que permite a un atacante acceder a archivos arbitrarios del servidor mediante la manipulación de parámetros que construyen rutas del sistema de archivos. Una medida de mitigación habitual consiste en validar que la ruta proporcionada por el usuario comience con el directorio base autorizado antes de servir el archivo. Esta variante del laboratorio explota precisamente una implementación incompleta de esa validación: el servidor comprueba únicamente que la cadena recibida empiece con el prefijo esperado, sin resolver ni verificar la ruta canónica final.

La validación de solo el inicio de la ruta ("validation of start of path") es una técnica de mitigación insuficiente porque opera sobre la cadena de texto tal como fue recibida, antes de que el sistema operativo o el framework normalicen las secuencias de retroceso de directorio (../). Un atacante puede anteponer el prefijo exigido por el filtro y, a continuación, encadenar suficientes secuencias ../ para escapar del directorio autorizado; la cadena completa sigue "empezando" con el prefijo válido, por lo que el filtro la deja pasar, pero la ruta se resuelve fuera del directorio permitido.

Estándar	Identificador	Descripción
CWE	CWE-22	Improper Limitation of a Pathname to a Restricted Directory
OWASP Top Ten	A01:2021	Broken Access Control — validación de entradas insuficiente
CVSS v3.x	Base Score: 7.5 (High)	Acceso no autorizado a archivos del sistema sin autenticación
CVSS Vector	AV:N/AC:L/PR:N/UI:N	Explotable remotamente, sin privilegios, sin interacción del usuario

La raíz de la vulnerabilidad reside en validar un fragmento de la entrada (su prefijo) en lugar de validar el resultado final de resolver esa ruta contra el sistema de archivos. Comprobar el inicio de la cadena, sin canonicalizar, equivale a no filtrar frente a un atacante que conozca el prefijo exigido. El único enfoque robusto es resolver la ruta canónica completa y verificar que dicha ruta —ya resuelta— permanece dentro del directorio base autorizado.

2. Identificación del Laboratorio

Campo	Detalle
Nombre del laboratorio	File Path Traversal — Validation of Start of Path
Nivel	Apprentice
Tipo de explotación	Path Traversal / Prefix (Start-of-Path) Validation Bypass
Plataforma	PortSwigger Web Security Academy

Campo	Detalle
Posición en la ruta	Actividad 11 — Road to Hall of Fame
Herramienta principal	Burp Suite Community Edition v2026.8
Protocolo explotado	HTTP/2
Vector de ataque	Parámetro filename del endpoint /image
Técnica de bypass	Prefijo válido seguido de secuencias ../ que resuelven fuera del directorio
URL del laboratorio	https://0a08003c03775398810757ff003600d7.web-security-academy.net/

3. Objetivo del Laboratorio

Objetivo general:

Demostrar de forma práctica y documentada la explotación de una variante de Path Traversal en la que la aplicación valida únicamente que el parámetro filename comience con el directorio base /var/www/images/, sin verificar la ruta canónica resultante. Mediante la construcción de un payload que antepone dicho prefijo a una secuencia de retroceso de directorio (/var/www/images/../../etc/passwd), se recuperará el contenido del archivo /etc/passwd del servidor objetivo.

Objetivos específicos

- Identificar la petición HTTP vulnerable con el parámetro filename (GET /image?filename=/var/www/images/49.jpg) en el historial de Burp Suite.
- Interceptar la petición y enviarla al módulo Repeater para su modificación controlada.
- Construir el payload /var/www/images/../../etc/passwd que conserva el prefijo exigido por el filtro y escapa del directorio autorizado.
- Verificar que el servidor responde con HTTP/2 200 OK y devuelve el contenido de /etc/passwd.
- Obtener la confirmación 'Lab Solved' de la plataforma PortSwigger.

4. Explicación Técnica de la Vulnerabilidad

La aplicación del laboratorio es una tienda en línea que sirve imágenes de producto a través del siguiente endpoint:

```
GET /image?filename=/var/www/images/49.jpg HTTP/2
Host: <lab-id>.web-security-academy.net
```

A diferencia de otras variantes del laboratorio, aquí el parámetro filename ya contiene la ruta absoluta completa, incluyendo el directorio base /var/www/images/. El servidor implementa un control de seguridad que consiste en comprobar que el valor recibido comience (startsWith) con ese directorio

autorizado. Sin embargo, esta comprobación se realiza sobre la cadena tal como llega, antes de resolver las secuencias `../` que pudiera contener.

Mecanismo del bypass. Si el atacante añade secuencias `../` después del prefijo exigido, la cadena completa sigue empezando con `/var/www/images/`, por lo que la validación de prefijo se supera sin problema. No obstante, cuando el sistema de archivos resuelve la ruta para abrir el archivo, cada `../` hace retroceder un nivel en la jerarquía de directorios — el prefijo validado no impide que, tras él, la ruta se aleje del directorio autorizado.

Valor del parámetro	Acción del filtro	Resultado
<code>/var/www/images/49.jpg</code>	Empieza con el prefijo autorizado — pasa	Sirve la imagen correctamente
<code>../../etc/passwd</code>	No empieza con el prefijo — bloqueado	Acceso denegado
<code>/var/www/images/../../etc/passwd</code>	Empieza con el prefijo — pasa (bypass)	Resuelve fuera del directorio — accede a <code>/etc/passwd</code>

5. Procedimiento Paso a Paso

Paso 1: Acceso al laboratorio y configuración de Burp Suite

Se accedió al laboratorio "File path traversal, validation of start of path" en PortSwigger Web Security Academy, disponible en <https://0a08003c03775398810757ff003600d7.web-security-academy.net/>. Se abrió Burp Suite Community Edition con la configuración predeterminada, con el proxy local activo en 127.0.0.1:8080.

Paso 2: Carga de la página en el navegador de Burp Suite

Desde la pestaña Proxy se abrió el navegador integrado de Burp Suite ('Open Browser'). Se navegó a la URL del laboratorio y se esperó a que la tienda en línea ('We Like To Shop') cargara completamente, quedando todo el tráfico disponible en el historial HTTP de Burp Suite.

Paso 3: Identificación del vector de ataque

En la pestaña Proxy > Intercept se identificó la petición GET `/image?filename=/var/www/images/49.jpg`, correspondiente a la carga de una imagen de producto. El valor del parámetro `filename` ya expone la ruta absoluta en el servidor, confirmando el vector de ataque.

Paso 4: Envío de la petición original al Repeater

La petición se envió al módulo Repeater de Burp Suite (Ctrl+R), donde se visualizó la petición original antes de cualquier modificación:

```
GET /image?filename=/var/www/images/49.jpg HTTP/2
```

```
Host: 0a08003c03775398810757ff003600d7.web-security-academy.net
```

Paso 5: Construcción y envío del payload de bypass

En el Repeater se modificó el valor del parámetro filename, conservando el prefijo /var/www/images/ exigido por el filtro y añadiendo tres secuencias de retroceso de directorio antes de etc/passwd. Se presionó el botón 'Send':

```
# Petición modificada con payload de bypass:  
GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2
```

Paso 6: Análisis de la respuesta

El panel de respuesta del Repeater mostró el código HTTP/2 200 OK y el cuerpo de la respuesta contenía el archivo completo /etc/passwd del sistema operativo del servidor, incluyendo la lista de usuarios del sistema (root, daemon, peter, carlos, entre otros).

Paso 7: Confirmación — Lab Solved

Se actualizó la página en el navegador integrado y la plataforma PortSwigger mostró el banner de confirmación 'Congratulations, you solved the lab!', validando el éxito del bypass.

6. Capturas de Pantalla Obligatorias

Se presentan las seis capturas de pantalla que documentan visualmente el proceso completo de explotación, desde el estado inicial del laboratorio hasta la confirmación de su resolución.

Captura 1 — Estado inicial del laboratorio

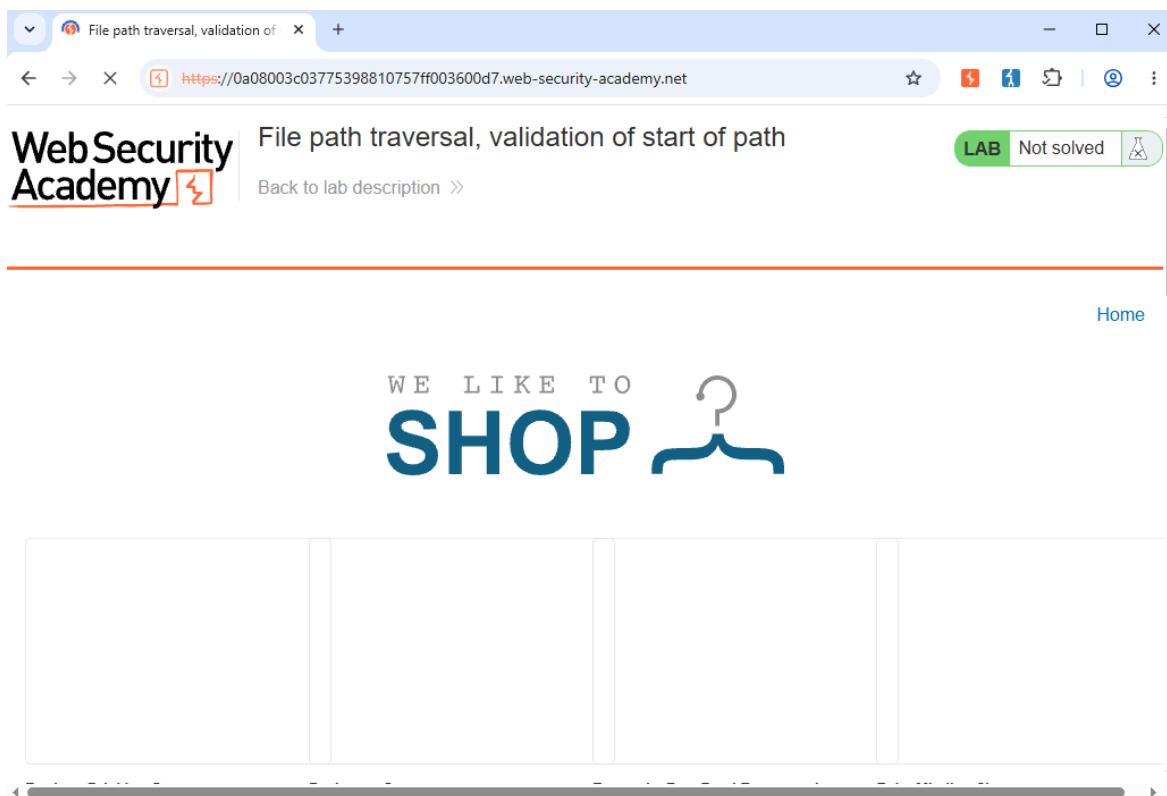


Figura 1. Estado inicial del laboratorio 'File path traversal, validation of start of path' en PortSwigger Web Security Academy, marcado como 'Not solved'.

Captura 2 — Petición interceptada en el Proxy

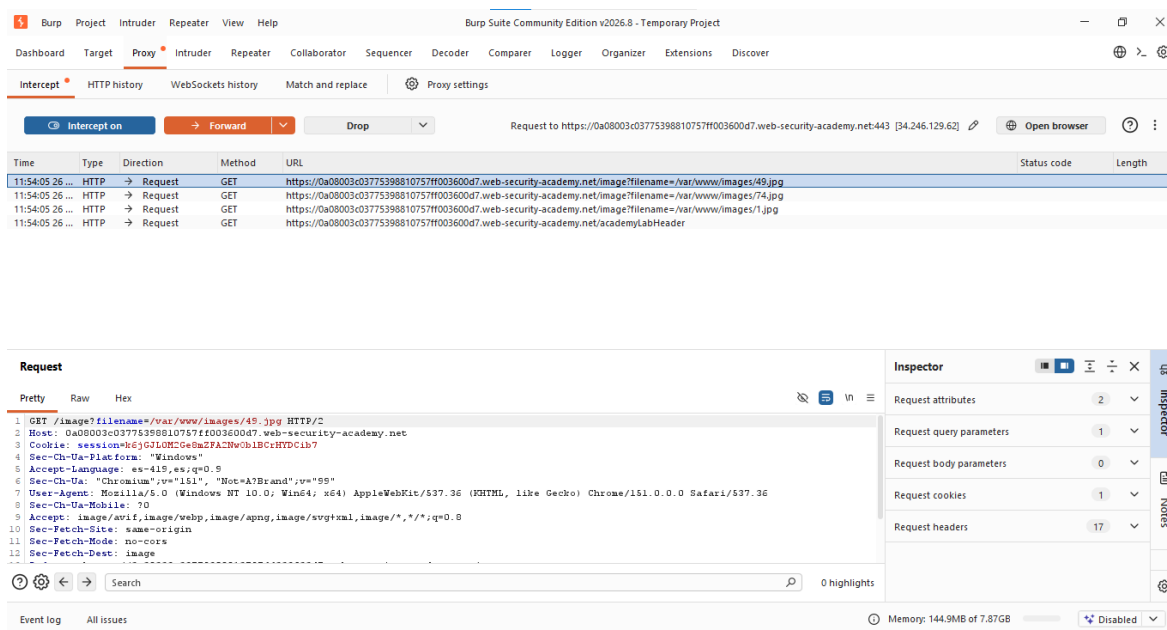


Figura 2. Historial HTTP de Burp Suite mostrando la petición GET /image?filename=/var/www/images/49.jpg interceptada, con la ruta absoluta del archivo expuesta en el parámetro.

Captura 3 — Petición original en el Repeater

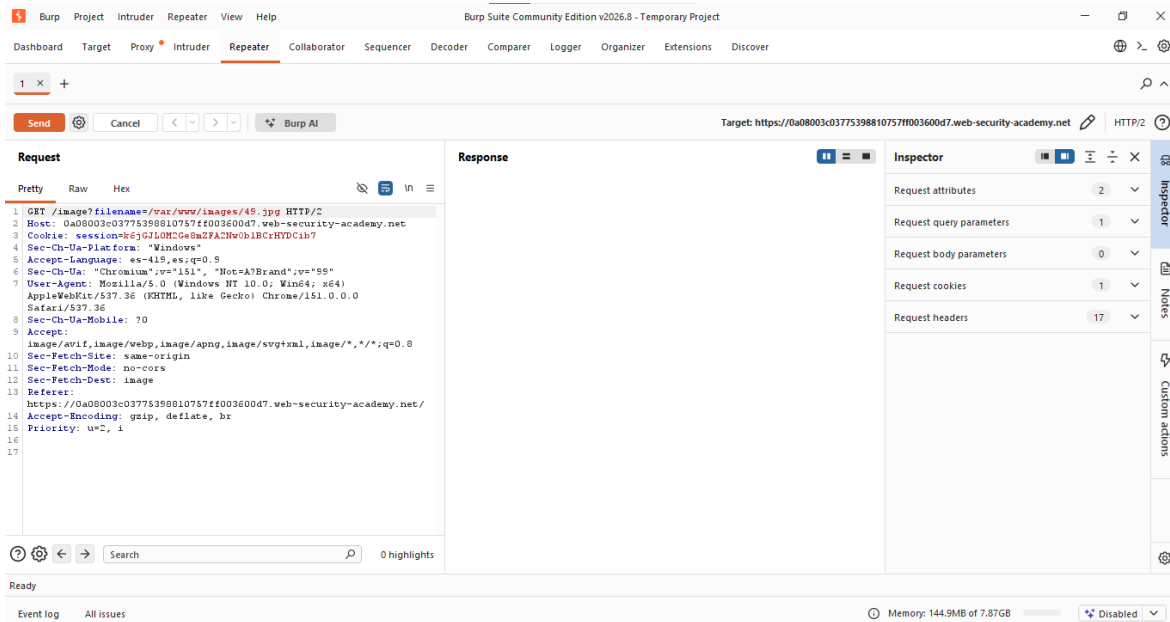


Figura 3. Petición original en el módulo Repeater de Burp Suite, lista para ser modificada.

Captura 4 — Payload de bypass enviado al servidor

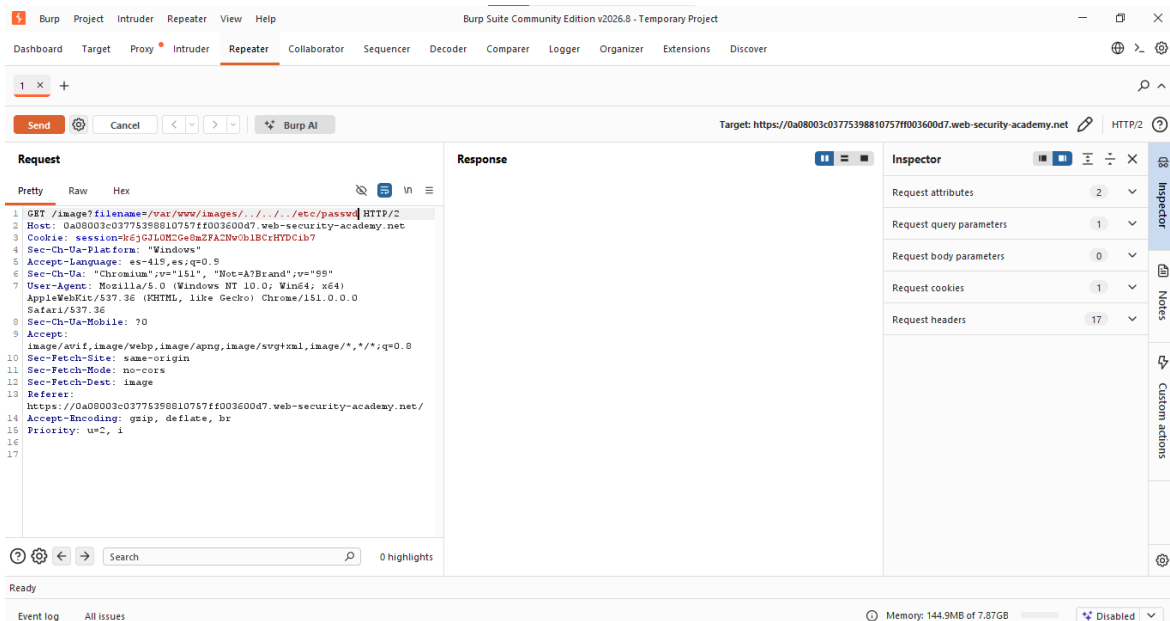


Figura 4. Petición modificada con el payload de bypass: GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2.

Captura 5 — Respuesta del servidor con el contenido de /etc/passwd

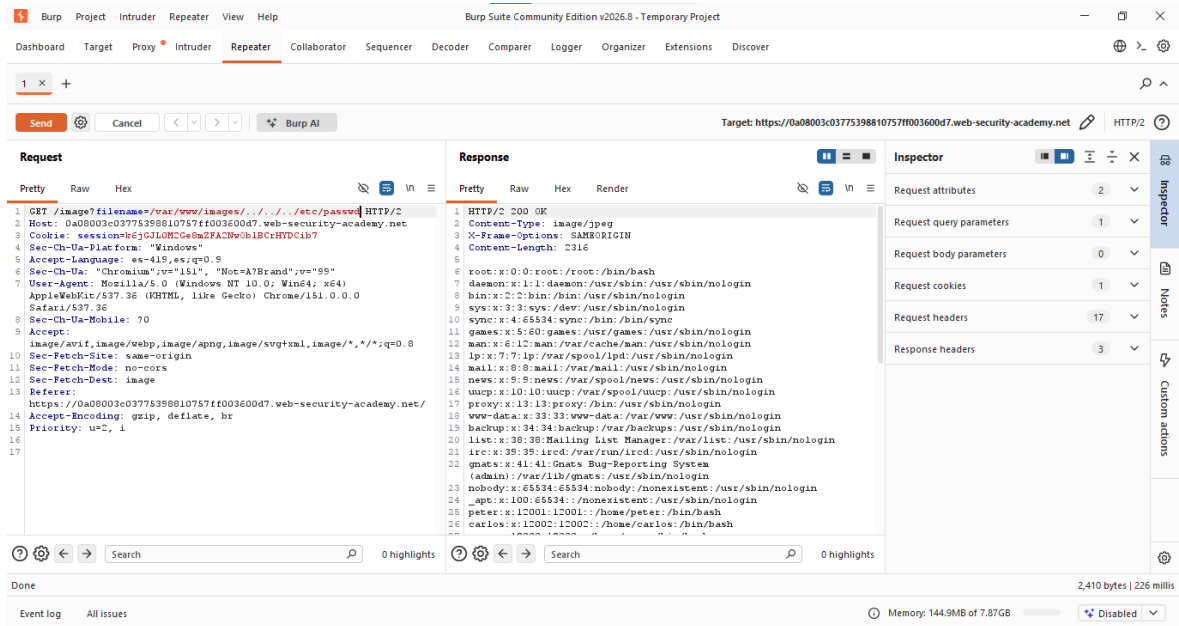


Figura 5. Respuesta HTTP/2 200 OK con el contenido completo del archivo `/etc/passwd`, incluyendo los registros de usuarios del sistema.

Captura 6 — Confirmación 'Lab Solved' de PortSwigger

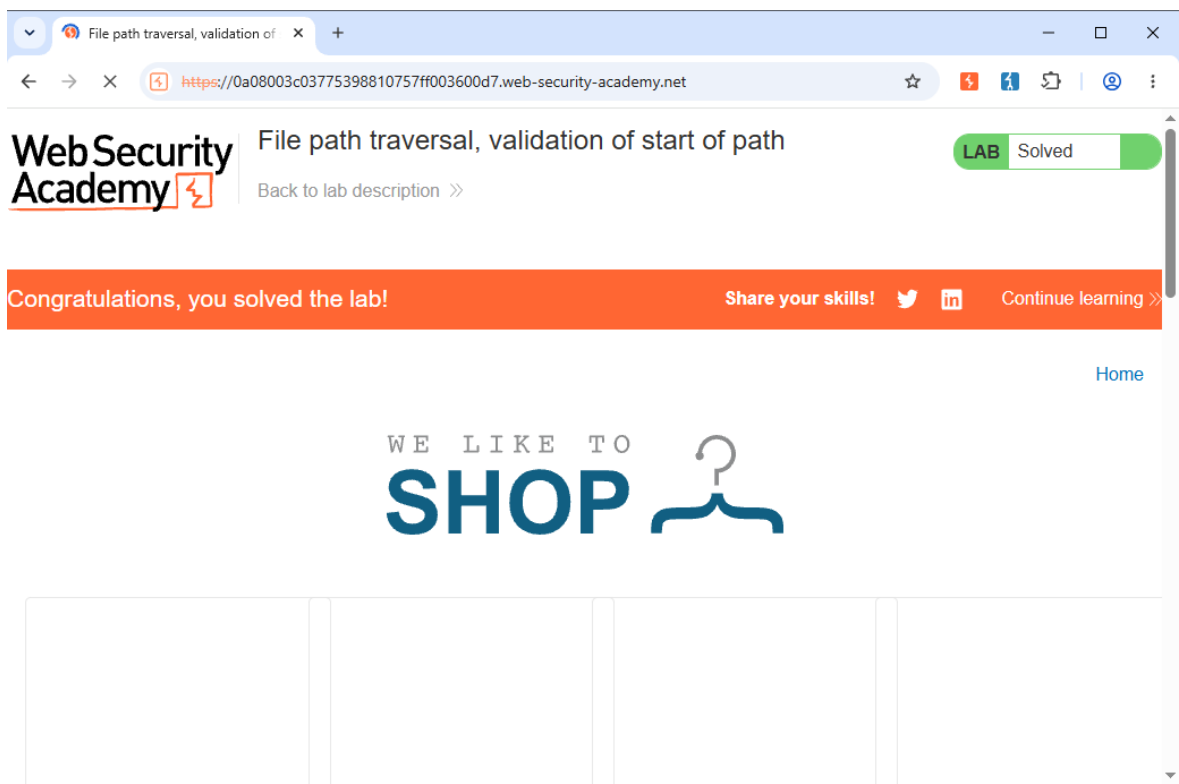


Figura 6. Banner de confirmación 'Congratulations, you solved the lab!' — laboratorio resuelto exitosamente.

7. Explicación Técnica del Payload

```
/var/www/images/../../../../etc/passwd
```

El payload se construye anteponiendo exactamente el prefijo que el filtro exige (/var/www/images/) para superar la validación de inicio de ruta, y añadiendo a continuación las secuencias ../ necesarias para retroceder desde ese directorio hasta la raíz del sistema de archivos:

Fragmento	Función en la ruta
/var/www/images/	Satisface la validación de prefijo (startsWith) exigida por el filtro
../	Retrocede del directorio images al directorio www
../	Retrocede del directorio www al directorio var
../	Retrocede del directorio var a la raíz del sistema de archivos
etc/passwd	Ruta al archivo objetivo desde la raíz

¿Por qué funciona con exactamente tres niveles? El directorio /var/www/images/ tiene tres niveles de profundidad desde la raíz (var, www, images). Por ello, tres secuencias ../ son suficientes para llegar a / antes de referenciar etc/passwd. El filtro nunca vuelve a evaluar la ruta después de confirmar el prefijo, por lo que no detecta que el resultado final abandona el directorio autorizado.

8. Mitigación Recomendada

8.1 Canonicalización y verificación de la ruta resultante (prioridad crítica)

La validación debe aplicarse sobre la ruta canónica ya resuelta, nunca sobre la cadena de texto recibida. Resolver primero la ruta completa y comparar el resultado —no el prefijo de la entrada original— contra el directorio base autorizado detiene este bypass y cualquier variante de ofuscación:

```
import os

BASE_DIR = os.path.realpath('/var/www/images')

def get_image(filename: str):
    full_path = os.path.join(BASE_DIR, os.path.basename(filename))
    canonical = os.path.realpath(full_path)
    if not canonical.startswith(BASE_DIR + os.sep):
        raise PermissionError('Acceso denegado')
    return open(canonical, 'rb').read()
```

8.2 Validación por allowlisting del valor del parámetro (prioridad crítica)

El cliente no debería poder enviar una ruta en absoluto. Definir exactamente qué valores son aceptables — por ejemplo, solo un nombre de archivo simple sin barras — elimina la superficie de ataque por completo:

```
import re

ALLOWED = re.compile(r'^[a-zA-Z0-9_-]+\.(jpg|jpeg|png|gif|webp)$')

def validate(filename: str) -> str:
    if not ALLOWED.match(filename):
        raise ValueError('Nombre de archivo no permitido')
    return filename
```

8.3 Por qué validar solo el inicio de la ruta es insuficiente

Comprobar que una cadena empiece con un prefijo autorizado es una operación puramente textual: no tiene en cuenta cómo el sistema operativo interpretará las secuencias `../` que aparezcan después de ese prefijo. Cualquier control de seguridad que no opere sobre la ruta canónica final es, en la práctica, equivalente a no filtrar frente a un atacante que conozca el directorio base.

Técnica de bypass	Ejemplo	¿Lo detiene la validación de prefijo?	¿Lo detiene la canonicalización?
Validación de solo el inicio	<code>/var/www/images/../../etc/passwd</code>	No	Sí
Ruta absoluta	<code>/etc/passwd</code>	Sí (no tiene el prefijo)	Sí
Codificación URL	<code>/var/www/images/..%2f..%2f..%2fetc%2fpasswd</code>	Depende del decodificador	Sí
Doble codificación	<code>/var/www/images/..%252f..%252f..%252fetc%252fpasswd</code>	No	Sí

8.4 Principio de mínimo privilegio y diseño seguro del endpoint

- Ejecutar el servidor web con un usuario sin privilegios que solo tenga permisos de lectura sobre el directorio de archivos estáticos.
- Aplicar controles a nivel del sistema operativo (chroot, namespaces, contenedores) para confinar el proceso del servidor web.
- Evitar exponer rutas de archivo en parámetros de URL; mapear internamente un identificador abstracto (ID numérico o UUID) al archivo real.
- Usar funciones del framework para servir archivos estáticos (`send_from_directory` en Flask, `StaticFiles` en FastAPI, `X-Accel-Redirect` en Nginx), que incluyen validación de ruta nativa.

9. Conclusión

La realización de este laboratorio permitió comprender una variante particular de bypass de Path Traversal basada en validar únicamente el inicio de la ruta proporcionada por el usuario. La aplicación exigía que el parámetro filename comenzara con el directorio base autorizado, pero al no verificar la ruta canónica resultante, dejó abierta la posibilidad de anteponer ese mismo prefijo a una secuencia de retroceso de directorio (`/var/www/images/../../etc/passwd`) que escapa del directorio permitido sin dejar de cumplir la condición textual impuesta por el filtro.

El caso ilustra un principio de seguridad fundamental: validar un fragmento de la entrada —como su prefijo— no equivale a validar el resultado final de resolver esa entrada contra el sistema de archivos. Cualquier control que opere sobre la cadena cruda, sin canonicalizar, es susceptible de ser rodeado por un atacante que conozca la condición exacta que el filtro comprueba.

El impacto del exploit es el mismo que en otras variantes de Path Traversal: lectura no autorizada del archivo `/etc/passwd` con la lista completa de usuarios del sistema operativo del servidor, información que puede aprovecharse para escalar el ataque mediante enumeración de cuentas, ataques de fuerza bruta y, en escenarios más complejos, lectura de archivos de configuración con credenciales de acceso.

La única mitigación verdaderamente robusta frente a esta familia de vulnerabilidades es resolver la ruta canónica completa y verificar el confinamiento al directorio base sobre ese resultado final, en lugar de sobre la cadena de texto recibida, ya que este enfoque es independiente de la técnica de ofuscación empleada por el atacante para construir el valor del parámetro.